

U.S. Department of Energy CyberForce Security Documentation

By Uzair Khan, Incident Response Team 64 SecOps, Section: System Hardening

Incident Overview:

In response to the recent cyber incidents affecting the Abyssal Pearl offshore platform, Obsidian Rift Energy has identified critical vulnerabilities across both its information technology (IT) and operational technology (OT) systems. This investigation highlights several security weaknesses that must be handled promptly and effectively. To address vulnerabilities and restore secure operations, Team 64 SecOps applied a comprehensive defense-in-depth approach, focusing on a layered defensive strategy to protect critical system functionality.

The following steps have been taken:

1. **Asset Enumeration & Network Scanning:** Initial documentation of the Abyssal Pearl's assets was incomplete, leaving gaps in IT and OT systems. To address this, Team 64 SecOps created a new network diagram and map for documentation. The new documentation produces a holistic inventory of Obsidian Rift's systems, including PLCs, HMI servers, web servers, databases, and workstations. Through this scanning, Team 64 SecOps has uncovered misconfigurations, leftover malware, and exposed credentials.

Security Tools and Techniques:

a) Mass Network Enumeration and Scanning

- i. [Nmap](#) & [Rustscan](#): Nmap is a popular tool for enumerating services on a particular system. Rustscan is a wrapper that speeds up the initial discovery of these services.
- ii. [Tenable Nessus Essentials](#): Tenable Nessus is considered the gold standard of vulnerability scanners among cybersecurity professionals. The Essential version is their free tier, which offers full vulnerability enumeration and still contains the ability to scan Obsidian Rift's entire network at once.

b) Individual System Configuration Evaluation

- i. [PEASS-ng](#): The Privilege Escalation Awesome Scripts Suite, or PEASS for short, is a collection of scripts for both Windows and Linux systems that attempt to identify potential methods to attain privilege escalation.
- ii. [Sysinternals Suite](#): The Microsoft Sysinternals Suite is a collection of applets that help system administrators manage and diagnose Windows systems.
- iii. [HardeningKitty](#): HardeningKitty is a PowerShell script that significantly speeds up the process of securing a Windows system by hardening its configuration.

- iv. [Lynis](#): Like HardeningKitty, Lynis is an auditing and hardening tool for Unix-based Systems.
- v. [Bloodhound](#): Bloodhound is a security tool used to analyze Active Directory (AD) permissions and relationships.

c) **Manual Efforts**

- i. File System Scanning for Leftover Malware: Incident Response Team 64 SecOps specialists reviewed file systems to identify any suspicious scripts (e.g. oil-gen.sh & cleaner.sh). Our findings report several malware and hacking tools present on various systems.
- ii. Log analysis for indicators of compromise: Both Windows and Linux record detailed event logs, which our specialists meticulously investigated to reconstruct the series of events preceding the ICS blackout, overpressure shutdown, and other security incidents.

Through these measures, Team 64 identified several high-risk vulnerabilities, including Mimikatz artifacts, plaintext passwords, domain misconfigurations, and insecure services.

2. **Removal of Unnecessary Services, Applications, and Protocols:** During the asset evaluation, Team 64 identified various systems running services that were either unused or insecure, including exposed SMB shares, unneeded Python binaries on OT hosts, and insecure WinRM listeners. To mitigate these risks, unnecessary binaries such as nc.exe and legacy SMB shares were disabled or removed. Firewall rules and network segmentation were verified to isolate critical hosts. These actions significantly reduced the attack surface and the potential for unauthorized access.
3. **Configure Access Control & Authentication Hardening:** Unsecured and overprivileged accounts and accounts with excessive permissions all present major security risks to both IT and OT systems. After evaluation of users and their privileges, Team 64 implemented the principle of least privilege, where each user has only the minimum necessary privileges for their duties. Overprivileged users' unnecessary privileges were revoked. Suspicious users, such as hacker and kertest, were removed, and AutoAdminLogon accounts were disabled.
4. **Update the Organization's Cybersecurity Plan:** Following the system hardening and security testing of Obsidian Rift's assets, several gaps were identified in the organization's cybersecurity policies and security controls, which necessitate a reevaluation. For instance, overprivileged user accounts emphasize the need for a clear access control policy, while operational technology (OT) requirements highlight the need for disaster recovery and business continuity plans. To ensure security policy and hardening procedures are robust, routine vulnerability scanning and penetration testing are essential for identifying gaps in the current security posture. As such, Incident

Response Team 64 SecOps conducted several vulnerability scans and system audits using open-source tools such as Nessus to verify that the hardening configuration was complete.

5. **Install and Configure Defensive Tools:** Incident Response Team 64 SecOps deployed a suite of operating system-level and network-level tools to detect, prevent, and respond to future cybersecurity incidents. All tools listed are open-source or freely available for cost-effective implementation within Obsidian Rift's systems. Other tools are available as options for future deployment.

a) **System Protections**

- i. UFW/Firewalld: Free and open-source firewalls for Linux systems.
- ii. ClamAV: Open-source antivirus solution for Linux systems.
- iii. Microsoft Defender: An effective anti-malware solution, when properly configured, which can be mass-managed in a Windows domain.
- iv. Suricata: Open source network-level intrusion detection and prevention system (IPS/IDS).

b) **Monitoring and Security Information and Event Management (SIEM):**

- i. Sysmon: A Sysinternals utility that enhances Windows event monitoring.
- ii. Auditd: A robust framework for monitoring security-related events on Linux systems.
- iii. Splunk/Wazuh/Netdata/Graylog: Free or open-source SIEM tools that aggregate logs and events from multiple systems into one platform.

However, for future reference, it may be necessary to invest in proprietary or closed-source software like Endpoint Detection and Response (EDR) and Runtime Application Self-Protection (RASP) tools.

Final Assessment

The security measures taken by Mobile Cybersecurity Response Team 64 SecOps reflect a robust layered defense-in-depth strategy that significantly improves Obsidian Rift's security posture. By addressing weaknesses in configurations and access management and implementing effective monitoring tools, the team reduced both the potential and impact of future cyber incidents. This defense-in-depth approach and security recommendations ensure that the Abyssal Pearl offshore platform is secure, functionally sound, and minimizes downtime so it can continue to support the Western U.S. energy supply. The frameworks and tools suggested during this incident response event provide a foundation for long-term protection of Obsidian Rift's vital assets, ensuring a strong security posture and business continuity.